

Actividad 1: Análisis y planificación del pentest

Danae Itziar Frutero Gutiérrez

Hacker Women Council- Ethical Hacking

1. Objetivo del pentest

Realizar una evaluación que permita conocer qué tan expuesta está la aplicación web de Aurora Market a ataques cibernéticos:

- Identificar que riesgos existen en la aplicación web
- Evaluar el impacto que podrían tener los riesgos si son explotados
- Proponer medidas que Aurora Market podría tomar para reducir sus riesgos

2. Alcance

Si se evaluará (Sistemas o elementos incluidos en el alcance):

- La aplicación web autorizada por Aurora Market

Fuera del alcance (Elementos que no serán evaluados):

- Redes sociales de la empresa
- Equipos personales de los empleados
- Cuentas de correo de los empleados
- Proveedores externos
- Otros sistemas relacionados con la empresa
- Acciones que puedan interrumpir deliberadamente el funcionamiento de la plataforma o afectar información real de los clientes

3. Autorización y condiciones

Permisos requeridos

- Aplicación web
- Base de datos
- Mecanismos de autenticación
- Tipos de usuarios

Condiciones acordadas

- Las pruebas se realizarán en horarios de menos actividad para reducir cualquier impacto sobre las operaciones
- La evaluación se realizará únicamente sobre la aplicación web
- No está permitido realizar acciones que puedan interrumpir el funcionamiento de la plataforma o afectar la información real de los clientes



4. Tipo de pentest

Gray Box

Justificación de la elección

Aurora Market no entrega toda la información técnica de su infraestructura ya que la empresa quiere que la evaluación permita conocer que podría descubrir un atacante dependiendo de la información que tenga disponible.

Aunque no se precisa cual es la información que Aurora Market proporciona, es información parcial.

5. Planificación

Que debería hacer el equipo antes de comenzar la parte técnica.

Objetivos: Realizar una evaluación que permita conocer qué tan expuesta está la aplicación web de Aurora Market a ataques cibernéticos; identificando los riesgos que existe, evaluando el impacto que podrían tener y proponiendo medidas que permitan reducirlos.

Alcance: Se evaluará la aplicación web autorizada por Aurora Market

Permisos y condiciones: No se evaluarán las redes sociales de los empleados, sus cuentas de correo, ni de proveedores externos. No se evaluarán otros sistemas relacionados con la empresa. No se realizarán acciones que puedan interrumpir deliberadamente el funcionamiento de la plataforma o que puedan afectar información real de los clientes.

Metodología a utilizar: PTES.

Recopilación de información previa: Utilizando herramientas OSINT y Who is para recopilar a la información pública disponible en la red. Para recopilar información activa se utilizará DNSdumpster y Nmap para comenzar a mapear la infraestructura.

Recursos necesarios: Computadora, documentación sobre PTES y las herramientas a emplear para la recopilación de información.

Programación del pentest: Se realizará de forma acordada con Aurora Market, una vez que se proporcione la información necesaria y verificar que sea horario de menor actividad, de acuerdo con las condiciones acordadas.

6. Fases del pentest

Explica como aplicarías cada fase al caso Aurora Market

¿Qué buscarías hacer en cada etapa?

1. **Reconocimiento:** Leer la documentación proporcionada por Aurora Market, incluido de forma detallada el reporte del usuario, en el que aseguraba haber visto información que aparentemente pertenecía a otra cuenta. Con el fin de entender la infraestructura y las necesidades de Aurora Market.

2. **Análisis de vulnerabilidades:** Utilizar herramientas que permitan detallar los activos de la empresa y ver cuáles de sus características podrían ser una vulnerabilidad, por ejemplo, versiones desactualizadas y puertos abiertos.
3. **Explotación:** La metodología empleada se realizará procurando tener el menor impacto dentro del alcance acordado.
4. **Post-Explotación:** Se evaluará el impacto de la explotación y si puede persistir.
5. **Informe:** Se utilizará la plantilla de PTES proporcionada en la clase.

7. Investigación

Metodología elegida

La metodología empleada será **PTES** debido a que es mi primer pentest y eso me permitiría tener un esqueleto claro, paso a paso de la prueba, además podría complementarlo consultando documentación de OWASP debido a su enfoque en seguridad de aplicaciones web